

DVBank Local Security Audit

A bounded assessment of an intentionally vulnerable DVBLab / DVBank application running on loopback.

Status: read-only local audit completed

Executive summary

Ran four low-impact HTTP checks against the locally hosted lab and reviewed selected Python source patterns. The tool recorded 19 findings: three runtime observations and 16 source-review flags. These are triage items, not 19 confirmed exploitable vulnerabilities.

Scope and method

Target limited to the local DVBLab instance on 127.0.0.1 / localhost. HTTP tests were read-only GET requests, did not follow redirects, used short timeouts, and discarded response bodies. Source review was limited to selected Python files.

Results

Category	Recorded results
Runtime checks (4)	Unauthenticated transaction-receipt response; missing browser security headers; credentialed CORS reflecting a harmless test origin.
Source review (16 flags)	One disabled JWT signature-verification pattern; eight MD5 call sites; three dynamic exec/eval patterns; four possible interpolated-SQL patterns. Manual reachability and impact review remains necessary.
Explicit negative check	Unauthenticated /api/me returned HTTP 401 as expected; this does not contradict the separate receipt-route observation.

Evidence screenshots

Figure 1. Audit report scope and first findings

```
### 15. [HIGH] MD5 Used in application code

akachi@akachi-ThinkPad-T440s:~/Documents/DVBLab$ head -40 ~/Documents/DVBLab/dvbank-audit-results/dvbank-audit-report.md
# DVBank Lab Local Audit

- **Run:** 2026-10-04T22:01:35-04:00
- **Scope:** DVBank Lab on loopback only
- **Checks:** read-only HTTP requests and optional local Python source review
- **Response data:** not included in reports

## Summary

- Findings: 19
- Runtime checks: 4

## Findings

### 1. [HIGH] Unauthenticated transaction receipt

- **Evidence:** A 2xx response means a receipt is reachable without authentication.
- **Recommended fix:** Require authentication and enforce transaction ownership before returning receipt data.
- **Method:** runtime

### 2. [MEDIUM] Missing browser security headers

- **Evidence:** Missing: CSP, X-Content-Type-Options, X-Frame-Options, Referrer-Policy
- **Recommended fix:** Set a restrictive CSP, X-Content-Type-Options: nosniff, X-Frame-Options or frame-ancestors, and Referrer-Policy.
- **Method:** runtime

### 3. [HIGH] Credentialed CORS reflects arbitrary origins

- **Evidence:** The response reflected the harmless test Origin https://audit.invalid and allowed credentials.
- **Recommended fix:** Use an explicit allowlist of trusted origins; never reflect arbitrary Origin values with credentials.
- **Method:** runtime

### 4. [CRITICAL] JWT signature verification disabled

- **Evidence:** backend/auth.py:25 decodes a JWT with verify_signature=False.
- **Recommended fix:** Reject invalid signatures; enforce an explicit algorithm allowlist and token expiry.
- **Method:** source review
```

Terminal excerpt of the local DVBank audit report showing scope, four runtime checks, and 19 total findings. The finding list includes automated source-pattern flags that still require manual validation.

Figure 2. Loopback-only lab, negative check, and audit run

```
akachi@akachi-ThinkPad-T440s:~/Documents/DVBLab$ docker compose ps
curl -i http://127.0.0.1:5000/api/me
WARN[0000] /home/akachi/Documents/DVBLab/docker-compose.yml: the attribute 'version' is obsolete, it will be ignored, please remove it to avoid potential confusion
NAME                IMAGE                COMMAND                SERVICE    CREATED        STATUS        PORTS
dvblab-backend-1    dvblab-backend      "python app.py"        backend    11 seconds ago Up 10 seconds 127.0.0.1:5000->5000/tcp
dvblab-frontend-1   dvblab-frontend      "docker-entrypoint.s..." frontend    34 minutes ago Up 32 minutes 127.0.0.1:3000->3000/tcp
HTTP/1.0 401 UNAUTHORIZED
Content-Type: application/json
Content-Length: 34
Server: Werkzeug/2.0.1 Python/3.9.25
Date: Mon, 05 Oct 2026 02:00:04 GMT

{
  "error": "Token is missing"
}

-----
akachi@akachi-ThinkPad-T440s:~/Documents/DVBLab$ python3 ~/Documents/DVBank-Local-Audit/dvbank_audit.py --source ~/Documents/DVBLab
Checks completed: 4 runtime checks; 19 findings
Report: dvbank-audit-results/dvbank-audit-report.md
JSON: dvbank-audit-results/dvbank-audit-findings.json
```

docker compose ps shows the backend and frontend bound to 127.0.0.1 only. An unauthenticated GET /api/me returns HTTP 401 (Token is missing), the expected negative result. Below the dashed line (backend log lines omitted), the audit runner completes 4 runtime checks and 19 findings. Terminal capture, 22:03.

Evidence screenshots (continued)

Figure 3. Source-review flags requiring manual validation

```
### 8. [CRITICAL] Dynamic code execution
- **Evidence:** backend/routes/admin_routes.py:363 calls exec().
- **Recommended fix:** Remove dynamic evaluation of request-controlled input; use a constrained parser or fixed operations.
- **Method:** source review

### 9. [CRITICAL] Dynamic code execution
- **Evidence:** backend/routes/admin_routes.py:337 calls eval().
- **Recommended fix:** Remove dynamic evaluation of request-controlled input; use a constrained parser or fixed operations.
- **Method:** source review

### 10. [HIGH] MD5 used in application code
- **Evidence:** backend/routes/admin_routes.py:393 calls MD5; inspect whether it protects passwords, tokens, or integrity.
- **Recommended fix:** Use Argon2id/bcrypt/scrypt for passwords and a modern keyed construction for tokens.
- **Method:** source review

### 11. [HIGH] Potential SQL built from interpolated input
- **Evidence:** backend/routes/auth_routes.py:23 passes a formatted or concatenated expression to execute().
- **Recommended fix:** Replace string-built SQL with parameterized queries and validate input.
- **Method:** source review

### 12. [HIGH] MD5 used in application code
- **Evidence:** backend/routes/auth_routes.py:21 calls MD5; inspect whether it protects passwords, tokens, or integrity.
- **Recommended fix:** Use Argon2id/bcrypt/scrypt for passwords and a modern keyed construction for tokens.
- **Method:** source review

### 13. [HIGH] Potential SQL built from interpolated input
- **Evidence:** backend/routes/auth_routes.py:37 passes a formatted or concatenated expression to execute().
- **Recommended fix:** Replace string-built SQL with parameterized queries and validate input.
- **Method:** source review

### 14. [HIGH] MD5 used in application code
- **Evidence:** backend/routes/auth_routes.py:175 calls MD5; inspect whether it protects passwords, tokens, or integrity.
- **Recommended fix:** Use Argon2id/bcrypt/scrypt for passwords and a modern keyed construction for tokens.
- **Method:** source review

### 15. [HIGH] MD5 used in application code
```

Findings 8 to 15: `exec()` and `eval()` call sites in `admin_routes.py`, MD5 usage, and interpolated SQL patterns in `auth_routes.py`. These are automated pattern matches that still need reachability and impact review, not confirmed exploits. Terminal capture, 22:14.

DVBank Local Security Audit | Analyst notes

Recommended follow-up

1. Require authentication and transaction ownership checks on receipt data; manually verify the response contents and authorization model.
2. Set explicit trusted CORS origins and review security headers for the app's deployment context.
3. Verify JWT signatures and allowed algorithms; remove dynamic evaluation where possible.
4. Use parameterized database queries; review each MD5 call in context, especially whether it affects password storage.
5. Retest fixes in the same isolated lab and retain before/after evidence.

Limitations

The lab is deliberately vulnerable and fictional. Static pattern flags do not prove exploitability, and four runtime checks are not comprehensive coverage. No destructive testing, password guessing, transfers, public exposure, or real customer data was involved.

Evidence basis

Audit runner output and saved DVBank case-study notes. The full screenshot-backed audit is available separately; this summary preserves the four-check / 19-finding distinction.

Skills demonstrated

Python, Docker Compose, low-impact web testing, source review, findings triage, and remediation writing.

Portfolio integrity note: This report describes an educational demonstration. It is not a client engagement, production security assessment, or certification of control effectiveness.